



Check List Security MVola Developer

Check list sécurité

SITE WEB

#	Nom	Contrôle	Description
1	HTTPS	- S'assurer que le site est bien en HTTPS et non HTTP - S'assurer que le certificat est valide et délivré par une autorité tierce reconnue (eg. IdenTrust, DigiCert, Sectigo, GlobalSign, etc.)	"HTTPS est la version sécurisée du protocole HTTP, qui assure notamment le chiffrement des échanges entre le client et serveur et prévient de certaines attaques. Remarque : la présence de HTTPS va de pair avec le contrôle suivant concernant le HSTS (HTTP Strict Transport Security)."
2	HTTP Strict Transport Security (HSTS)	S'assurer que le HSTS est activé dans les en-têtes de la page. Une entête similaire à celle qui suit doit être présente dans les réponses HTML de la page : Strict-Transport-Security : max-age=<expire-time>; includeSubDomains Avec expire-time la durée en secondes pendant laquelle la connexion HTTPS doit être forcée, généralement un nombre très grand, et includeSubDomains une option qui permet d'inclure ou non les sous-domaines du serveur	Force la redirection vers HTTPS de toutes les interactions des agents clients et web avec le serveur. Certains sites HTTPS restent en effet accessibles en HTTP. Avec une redirection vers HTTPS, le HSTS force ainsi toute communication à passer par HTTPS. Ce contrôle va donc de pair avec le contrôle précédent sur la présence de HTTPS.
3	Updates	S'assurer que tous les logiciels et librairies utilisées pour le site sont à jours, ou le cas contraire qu'aucune faille de sécurité majeure demeure non-couverte.	Les sites WEB utilisent généralement plusieurs librairies (PHP, JavaScript etc.) qu'il est essentiel de maintenir à jour lorsque des failles de sécurité sont couvertes.

#	Nom	Contrôle	Description
4	"Cross Site Scripting Protection (X-XSS)"	S'assurer que la protection anti Cross-Site Scripting (X-XSS) est désactivé dans les en-têtes de la page avec la ligne suivante : X-XSS-Protection : 0	Le cross-site scripting, ou XSS / X-XSS est un type de faille de sécurité des sites web permettant d'injecter du contenu dans une page, provoquant ainsi des actions indésirées sur les navigateurs web visitant la page. La protection X-XSS est cependant dépréciée et il convient donc de vérifier qu'elle est bien désactivée. Le cross-site scripting est désormais évité par le Content Security Policy (CSP).
5	Content Security Policy (CSP)	S'assurer que le CSP est activé dans les en-têtes de la page. Le paramètre suivant est attendu dans les headers HTML : Content-Security-Policy	Le CSP, ou Content Security Policy est un mécanisme de sécurité standardisé permettant de restreindre l'origine du contenu dans une page web à certains sites autorisés. Un navigateur compatible avec CSP n'exécute que les scripts provenant d'une origine autorisée par les règles CSP reçues et ignore ceux qui ne sont pas autorisés.
6	Browser Sniffing Protection (X-Content-Type-Options)	S'assurer que la ligne suivante de protection anti-sniffing est présente dans les en-têtes HTML : X-Content-Type-Options : nosniff	Cet en-tête empêche le navigateur d'effectuer du sniffing de type MIME (système d'écoute discrète des informations qui transitent)

#	Nom	Contrôle	Description
7	"Clickjacking Prevention (X-Frame-Options)"	S'assurer qu'une des 3 lignes suivantes est présente dans les en-têtes HTML du site : - X-Frame-Options : "deny" : désactive iFrame entièrement - X-Frame-Options : "sameorigin" : iFrame uniquement pour la même origine - X-Frame-Options : "allow-from" : iFrame uniquement sur liste blanche	La balise iframe est une balise permettant d'afficher sur une page web le contenu d'une autre page. L'utilisation d'iframe est une pratique courante mais ces balises peuvent être utilisées pour de mauvaises intentions et devenir ainsi un vecteur d'attaques. En effet, il est possible pour un pirate d'embarquer une page web dans un iframe et d'en modifier le comportement...
8	"Referring Settings (Referrer-Policy)"	S'assurer qu'un en-tête similaire est présente dans les réponses HTML de la page : Referrer-Policy : <option> De nombreuses options existent en fonction des cas : no-referrer, origin, strict-origin, etc. Pour plus d'informations, se rendre à cette adresse : https://developer.mozilla.org/fr/docs/Web/HTTP/Headers/Referrer-Policy	Un référent, ou Referrer, est une information transmise à un serveur HTTP lorsqu'un visiteur suit un lien pour accéder à l'une de ses ressources, lui indiquant l'URL de la page où se situe ce lien qu'il a suivi. Il peut être utile dans certains cas (outils de statistiques) mais peut poser des problèmes de confidentialité, il est donc nécessaire de les paramétrer en fonction des besoins de site.

#	Nom	Contrôle	Description
9	"Cookie Settings (Set-Cookie)"	S'assurer qu'un des 3 options suivantes est paramétrée pour les cookies au niveau des en-têtes HTML du site : Secure, HttpOnly et SameSite. - Secure : cookies ne passent que par HTTPS et évite ainsi les attaques par homme du milieu (MITM) - HttpOnly : cookies non accessibles par Javascript -> en cas d'attaque XSS les cookies ne seront pas récupérables par l'attaquant - SameSite : cookies ne seront pas envoyés à un autre site. Aide à prévenir contre les attaques par Cross-Origin Request Forgery (SCRF) Les options HttpOnly et Secure sont recommandées. SameSite n'est disponible que sur Opera et Chrome pour le moment.	Le protocole HTTP utilise des cookies, de petits fichiers textes stockés sur le terminal utilisateur qui contiennent des informations de connexion, afin de faciliter la navigation sur le site. De nombreuses informations circulent par ces cookies et il est essentiel de les paramétrer correctement.

Check list sécurité

APPLICATION MOBILE

V1	Architecture, Design et Modèle de Menaces
1.1	Tous les composants de l'application sont identifiés et leur besoin est confirmé. (Activity, Services, Broadcast Receivers...)
1.2	Les contrôles de sécurité ne sont pas mis en oeuvre seulement côté client, mais aussi sur les points terminaux distants.
1.3	Une architecture de haut niveau concernant l'application mobile et tous les services distants utilisés a été définie et la sécurité a été prise en compte dans cette architecture.
1.4	Les données considérées comme sensibles dans le contexte de l'application mobile sont clairement identifiées.
1.5	Tous les composants de l'application sont définis en termes des fonctions métier et/ou de sécurité qu'ils apportent.
1.6	Un modèle de menaces pour l'application mobile et les services distants associés a été livré et définit les menaces potentielles et les contre-mesures associées.
1.7	Tous les contrôles de sécurité ont une implémentation centralisée.
1.8	Il existe une politique explicite sur la façon de gérer les clés de cryptographie (dès qu'elles existent) tout au long de leur cycle de vie. Idéalement, un standard de gestion des clés est suivi (tel que NIST SP 800-57).
1.9	Un mécanisme pour permettre les mises à jour de l'application mobile existe.
1.10	La sécurité est prise en compte tout au long du cycle de développement.

V2	Stockage des données et Respect de la Vie Privée
2.1	Les fonctions de stockage sécurisées proposées par les systèmes sont utilisées de manière appropriée pour stocker les données sensibles tels que les informations personnellement identifiables (PII), les références des utilisateurs ou les clés cryptographiques.
2.2	Aucune donnée sensible ne devrait être stockée hors du conteneur de l'application ou des fonctions de stockage sécurisées proposées par le système.
2.3	Aucune donnée sensible n'est écrite dans les journaux applicatifs.
2.4	Aucune donnée sensible n'est partagée avec des tierces parties à moins que cela ne soit un besoin de l'architecture.
2.5	Le cache du clavier est désactivé sur les champs d'entrée textuels qui traitent de données sensibles.
2.6	Aucune donnée sensible n'est exposée par les mécanismes d'IPC.
2.7	Aucune donnée sensible, tels que les mots de passe ou les codes PIN, n'est exposée à travers l'interface utilisateur.
2.8	Aucune donnée sensible n'est incluse dans les sauvegardes générées par le système d'exploitation mobile.
2.9	L'application enlève les données sensibles des vues lors de son passage en arrière-plan.
2.10	L'application ne garde pas les données sensibles en mémoire plus longtemps que nécessaire et la mémoire est explicitement nettoyée après son utilisation.
2.11	L'application met en oeuvre un minimum de politique concernant la sécurité de l'accès à l'appareil tel que l'obligation pour l'utilisateur de définir un code d'accès à l'appareil.
2.12	L'application instruit l'utilisateur sur les types d'information personnellement identifiable traités ainsi que sur les bonnes pratiques que l'utilisateur devrait suivre en utilisant l'application.

V3	Cryptographie
3.1	L'application n'utilise pas la cryptographie symétrique avec des clés codées en dur comme seule méthode de chiffrement.
3.2	L'application utilise des implémentations de primitives cryptographiques éprouvées.
3.3	L'application utilise des primitives cryptographiques appropriées au cas d'utilisation, configurées en adéquation avec les bonnes pratiques de Sécurité de l'Information.
3.4	L'application n'utilise pas de protocole ou d'algorithme de cryptographie considéré par la communauté comme déprécié pour des raisons de sécurité.
3.5	L'application ne ré-utilise pas la même clé de cryptographie à des fins différentes.
3.6	Toute valeur aléatoire est générée par un générateur de nombres aléatoires offrant un bon niveau de sécurité.

V4	Authentification et gestion des Sessions
4.1	Si l'application donne accès aux utilisateurs à un service distant, un certain niveau d'authentification, tel que l'authentification par nom d'utilisateur / mot de passe, est faite sur le point terminal distant.
4.2	Si des sessions avec état sont utilisées, le point terminal distant utilise des identifiants de session aléatoirement générés pour authentifier les requêtes des clients sans avoir à envoyer les références des utilisateurs.
4.3	Si l'authentification sans état basée sur des jetons est utilisée, le serveur fournit des jetons qui ont été signés par un algorithme à la sécurité éprouvée.
4.4	Le point terminal distant met fin à la session existante lorsque l'utilisateur se déconnecte.
4.5	Une politique de mot de passe existe et est appliquée sur le point terminal distant.
4.6	Le point terminal distant implémente un mécanisme permettant la protection contre les essais répétés de références utilisateurs.
4.7	Les sessions sont dévalidées sur le point terminal distant après une période d'inactivité donnée et les jetons d'accès associés expirent.
4.8	L'authentification biométrique, lorsqu'elle est utilisée, n'est pas basée sur des événements (c'est-à-dire l'utilisation d'une API qui retourne simplement "vrai" ou "faux"). A la place, son utilisation est basée sur le déverrouillage du trousseau d'accès / du magasin de clé (keychain / keystore).
4.9	Un second facteur d'authentification est disponible sur le point terminal distant et l'exigence d'authentification à deux facteurs est mise en application de façon systématique.
4.10	Les transactions sensibles requièrent une authentification améliorée.
4.11	L'application informe les utilisateurs de toutes les connexions sur leurs comptes. Les utilisateurs ont accès à la liste des appareils utilisés pour accéder à leurs comptes et peuvent en bloquer.

V5	Communication réseau
5.1	Les données sont cryptées sur le réseau en utilisant TLS. Le canal sécurisé est utilisé systématiquement à travers toute l'application.
5.2	Les réglages de TLS sont en ligne avec les meilleures pratiques, ou aussi proches que possible dans le cas où le système d'exploitation ne supporte pas les standards recommandés.
5.3	L'application valide le certificat X.509 du point terminal distant lors de l'établissement du canal sécurisé. Seuls les certificats signés par une CA de confiance sont acceptés.
5.4	Soit l'application utilise son propre magasin de certificats, ou bien elle épingle le certificat du point terminal ou sa clé publique, et par là n'établit pas de connexion avec des points terminaux qui proposent des certificats ou des clés différents, même s'ils sont signés par des CA de confiance.
5.5	L'application ne repose pas sur un canal de communication non-sécurisé unique (e-mail ou SMS) pour les opérations critiques telles que l'enregistrement ou la récupération de compte.
5.6	L'application implémente l'état de l'art en termes de connectivité et de librairies de sécurité.
4.7	Les sessions sont dévalidées sur le point terminal distant après une période d'inactivité donnée et les jetons d'accès associés expirent.
4.8	L'authentification biométrique, lorsqu'elle est utilisée, n'est pas basée sur des événements (c'est-à-dire l'utilisation d'une API qui retourne simplement "vrai" ou "faux"). A la place, son utilisation est basée sur le déverrouillage du trousseau d'accès / du magasin de clé (keychain / keystore).
4.9	Un second facteur d'authentification est disponible sur le point terminal distant et l'exigence d'authentification à deux facteurs est mise en application de façon systématique.
4.10	Les transactions sensibles requièrent une authentification améliorée.
4.11	L'application informe les utilisateurs de toutes les connexions sur leurs comptes. Les utilisateurs ont accès à la liste des appareils utilisés pour accéder à leurs comptes et peuvent en bloquer.

V6	Intéractions avec la plateforme
6.1	L'application ne demande qu'une série minimum de permissions nécessaires.
6.2	Toutes les entrées provenant de sources externes ainsi que des utilisateurs sont validées et si nécessaire assainies. Ceci inclut les données reçues via l'interface utilisateur, les mécanismes IPC tel que les intentions, les URL propres à l'application et les sources sur le réseau.
6.3	L'application n'exporte pas de fonctionnalité sensible via des schémas d'URL propres à l'application, à moins que ces mécanismes ne soient correctement protégés.
6.4	L'application n'exporte pas de fonctionnalité sensible à travers les possibilités IPC, à moins que ces mécanismes ne soient correctement protégés.
6.5	JavaScript est désactivé dans les WebViews à moins qu'il ne soit explicitement requis.
6.6	Les WebViews sont configurées pour ne permettre que le jeu minimum de gestionnaires de protocoles requis (idéalement, seul https est supporté). Les gestionnaires potentiellement dangereux, tels que ceux pour les fichiers, les appels téléphoniques ou l'identifiant de l'application sont désactivés.
6.7	Dans le cas où des méthodes natives de l'application sont exposées à une WebView, il convient de valider que la WebView ne rend que le JavaScript contenu dans le package de l'application.
6.8	La désérialisation des objets, s'il en existe, est implémentée à l'aide d'API de sérialisation de confiance.

V7	Qualité du code et paramètres de génération
7.1	L'application est signée et livrée avec un certificat en cours de validité, dont la clé privée est correctement protégée.
7.2	L'application a été générée en mode release avec des réglages appropriés à ce mode (c.a.d. sans les possibilités de débogage).
7.3	Les symboles pour le débogage ont été enlevés des binaires natifs.
7.4	Le code de débogage a été enlevé de l'application et celle-ci ne journalise ni de messages d'erreur inutilement longs ni de messages de débogage.
7.5	Tous les composants utilisés par l'application provenant de sources externes, notamment les librairies et les frameworks, ont été identifiés et analysés à la recherche de vulnérabilités connues.
7.6	L'application intercepte et gère les exceptions potentielles.
7.7	La logique de gestion des erreurs dans les contrôles de sécurité refuse tout accès par défaut.
7.8	Dans le code non-géré, la mémoire est allouée, libérée et utilisée de façon sécurisée.
7.9	Les fonctionnalités de sécurité intégrées dans les outils de la chaîne de génération, par exemple ceux pour la minification de byte-code, pour la protection de la pile, pour le support PIE ou le comptage de références automatiques, sont activées.

V8	Exigences de résilience contre la rétro-ingénierie
	Entraver l'Analyse Dynamique et la Modification
8.1	L'application détecte et réagit à la présence d'appareils rootés ou jailbreakés soit en alertant l'utilisateur ou en mettant fin à l'application.
8.2	L'application empêche le déboggage et / ou réagit à la présence d'un déboggeur. Tous les protocoles de déboggage disponibles doivent être couverts.
8.3	L'application détecte et réagit à la modification de fichiers exécutables et de données critiques au sein de son bac à sable.
8.4	L'application détecte et réagit à la présence d'outils et de frameworks de rétro-ingénierie courants sur l'appareil.
8.5	L'application détecte et réagit à son exécution dans un émulateur.
8.6	L'application détecte et réagit à la modification de code et de données dans son espace mémoire.
8.7	L'application implémente plusieurs mécanismes parmi les catégories de défense (8.1 à 8.6). Il convient de noter que la résilience augmente avec la quantité et la diversité de l'originalité des mécanismes utilisés.
8.8	Les mécanismes de détection déclenchent des réponses de différents types, notamment des réponses invisibles de retardement de l'attaque.
8.9	L'obscurcissement est mis en oeuvre par des défenses programmatiques qui, à leur tour, entravent le dé-obscurcissement via l'analyse dynamique.
	Liaison avec un Appareil
8.10	L'application implémente un mécanisme de 'liaison avec l'appareil' utilisant une empreinte de l'appareil dérivée de multiples propriétés uniques à cet appareil.
	Entraver la compréhension
8.11	Tous les fichiers exécutables et les bibliothèques appartenant à l'application sont soit chiffrés au niveau du fichier et / ou le code important et les segments de données à l'intérieur des exécutables sont chiffrés ou compactés. Une analyse statique triviale ne révèle pas de code important ou de données.
8.12	Si le but de l'obscurcissement est de protéger des traitements sensibles, le schéma d'obscurcissement utilisé est à la fois approprié à la tâche considérée et est résistant envers les méthodes de dé-obscurcissement manuelles et automatiques, en prenant en considération les recherches disponibles. L'efficacité du schéma d'obscurcissement doit être validée à travers du test manuel. Il convient de noter que les fonctionnalités d'isolation au niveau matériel doivent être mises en pratique de préférence à l'obscurcissement toutes les fois que cela est possible.